

OFFSEC

PENTEST



2

LISTA DE FIGURAS

Figura 1 – Pentest	5
Figura 2 – Etapas do pentest	7
Figura 3 – Escopo do pentest.....	15
Figura 4 – Instalação Gráfica	21
Figura 5 - Português Brasil.....	22
Figura 6 – Linguagem	22
Figura 7 – Brasil	23
Figura 8 - Português Brasileiro	23
Figura 9 - Carregando Componentes.....	24
Figura 10 - Nome da máquina.....	24
Figura 11 - Nome do domínio.....	25
Figura 12 – Senhas	25
Figura 13 – Relógio	26
Figura 14 – Disco	26
Figura 15 - Selecionar disco.....	27
Figura 16 - Selecionar Partição	27
Figura 17 - Aplicar Particionamento	28
Figura 18 - Escrever mudanças	28
Figura 19 - Instalando Sistema.....	29
Figura 20 - Espelho de rede.....	29
Figura 21 – Proxy	30
Figura 22 - Terminando instalação.....	30
Figura 23 - Configurando GRUB	31
Figura 24 - Instalando GRUB	31
Figura 25 - Finalizar Instalação	32
Figura 26 - Login como root	32

SUMÁRIO

PENTEST	4
1 INTRODUÇÃO	4
2 PENETRATION TEST	5
3 ETAPAS DO PENTEST	7
4 COMUNICAÇÃO NO PROCESSO DE PENTEST	9
4.1 O caminho da comunicação ou cadeia de comando	9
4.2 Comunicação com o cliente	9
4.3 Comunicação dentro da equipe de pentest	9
4.4 Quais informações comunicar e quando?	10
4.5 Briefings regulares de progresso dentro da equipe	10
4.6 Briefings regulares de progresso com o cliente	11
4.7 Identificação clara do raciocínio por trás das atividades de comunicação	11
4.8 Possíveis ajustes no trabalho	12
4.9 Divulgação dos resultados	12
5 CONTRATO DE PENTEST	12
5.1 Contrato de serviço principal	12
5.2 Declaração de trabalho e acordo de não divulgação (NDA)	13
5.3 Autorizações	13
6 ESCOPO DO PENTEST	14
6.1 Avaliações baseadas em conformidade	17
6.2 Black-box testing	18
6.3 Gray-box testing	18
6.4 White-box testing	18
6.5 Contrato de confidencialidade	20
6.6 Instalação Kali Linux	21
REFERÊNCIAS	33

PENTEST

1 INTRODUÇÃO

“Conheces teu inimigo e conhece-te a ti mesmo; se tiveres cem combates a travar, cem vezes serás vitorioso. Se ignoras teu inimigo e conheces a ti mesmo, tuas chances de perder e de ganhar serão idênticas. Se ignoras ao mesmo tempo teu inimigo e a ti mesmo, só contarás teus combates por tuas derrotas” (Sun Tzu, General Chinês - 544 a.C. - 496 a.C.).

De acordo com o último levantamento do LinkedIn com prospecções para 2022 apud CNN (2022), o cargo de engenheiro de Cyber Security será a segunda profissão mais promissora do mercado, o que indica que a demanda do mercado tende a ser maior que a oferta de profissionais bem capacitados. Porém, apesar de “estar na moda” e ser uma área relativamente nova, seu embrião foi concebido muito longe do mercado corporativo... Ela surgiu em organizações governamentais e militares. E por ser uma área irmã da Inteligência, a Cyber Security vem sendo fomentada em bancos acadêmicos militares há praticamente duas décadas.

Ao olharmos para as implementações da Cyber Security no dia a dia sob a ótica militar, vemos que alguns conceitos como **MZ** e **DMZ** (zona militarizada e desmilitarizada, respectivamente), **Ataque** e **Defesa**, **Levantamento de Informações**, **Reconhecimento** etc., começam a fazer mais sentido. Ou seja, estudar Cyber Security com um pano de fundo militarizado abre nossos olhos para entendermos a aplicabilidade de técnicas em cenários bem específicos.

Nesta fase, vocês serão imergidos no campo de batalha da cibersegurança, na qual receberão os treinamentos (e as “armas”) necessários para desempenhar papéis de ataque e defesa de infraestruturas críticas.

E aí, está preparado para os desafios do mercado corporativo?

2 PENETRATION TEST

Frequentemente, os termos "análise de vulnerabilidade" e "teste de penetração" são usados de forma intercambiável, embora não tenham o mesmo significado. A principal diferença entre os dois é a validação.

Análise de vulnerabilidade é a prática de avaliar um sistema de computador, uma rede ou um aplicativo para identificar possíveis pontos fracos. Geralmente, é realizada usando uma ferramenta automatizada, que produz uma lista de vulnerabilidades com base em assinaturas conhecidas. Muitas delas podem ser falsos positivos ou não realmente exploráveis.

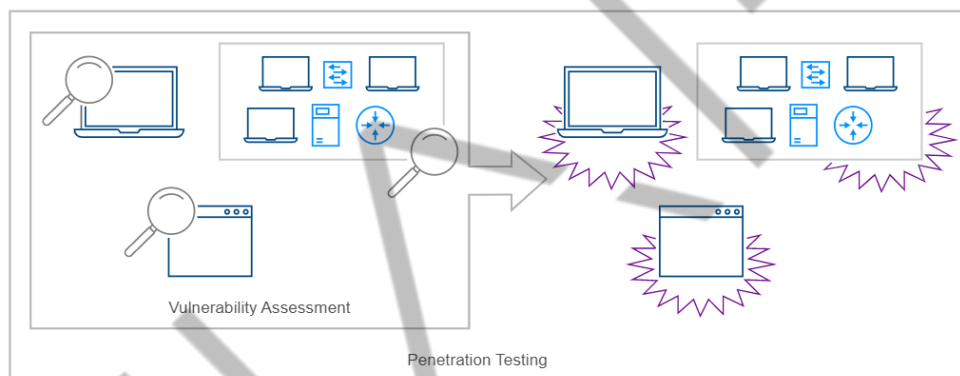


Figura 1 – Pentest
Fonte: Elaborado pelo autor (2019)

O teste de penetração, ou pentest, vai além do simples teste de vulnerabilidade. Ele procura explorar vulnerabilidades e produzir evidências de sucesso como parte de seu relatório. Geralmente inclui engenharia social e teste de controles físicos, além de testar fraquezas técnicas. Os benefícios da realização de testes pen são numerosos e incluem:

- Teste de recursos de defesa cibernética.
- Revelando vulnerabilidades em computadores, aplicativos e redes.
- Encontrar falhas de segurança e conectá-las antes que um invasor possa tirar proveito delas.
- Suporte ao gerenciamento de riscos eficaz, mostrando o risco real envolvido com as vulnerabilidades encontradas.

- Aprimorando o controle de qualidade, garantindo a continuidade dos negócios.
- Proteger clientes, parceiros e outros, além da reputação da organização.
- Garantir a conformidade com os regulamentos e certificações aplicáveis.
- Manter a confiança.

Vários conjuntos de padrões e estruturas foram desenvolvidos para fornecer uma base comum de entendimento e expectativa para testes de penetração. Alguns deles são descritos nos tópicos a seguir.

- **CHECK framework**

Desenvolvida pelo Communications-Electronic Security Group (agora o National Cyber Security Centre), que faz parte da sede de comunicações do governo do Reino Unido. Esse esquema garante que agências governamentais e entidades públicas possam contratar empresas certificadas para identificar vulnerabilidades em sua confidencialidade, integridade e disponibilidade (CIA), testando suas redes e outros sistemas.

Para mais informações, consulte: <www.ncsc.gov.uk/articles/check-fundamental-principles>

- **A estrutura de teste do Open Web Application Security Project (OWASP)**

Desenvolvida por uma organização multinacional que coleta e compartilha práticas de segurança com desenvolvedores de software, essa estrutura fornece pentest e outras técnicas de teste para cada parte do ciclo de vida de desenvolvimento de software.

Para mais informações, consulte: <www.owasp.org>

- **Manual de metodologia de teste de segurança de código aberto (OSSTMM)**

Desenvolvido pelo Instituto de Segurança e Metodologias Abertas (ISECOM), este documento é um guia revisado por pares para testes e análises de segurança que permite aumentar a segurança operacional.

Para mais informações, consulte: <<https://www.isecom.org/OSSTMM.3.pdf>>

- **Padrão de execução para teste de penetração (PTES)**

Desenvolvido por profissionais de serviços de segurança para fornecer aos profissionais de negócios e provedores de serviços de segurança um léxico básico e diretrizes para a realização de pentest. O PTES é o padrão geral, enquanto informações detalhadas são fornecidas no Guia Técnico do PTES.

Para mais informações, consulte: <www.pentest-standard.org>

- **NIST SP 800-115**

Desenvolvido pelo Instituto Nacional de Padrões e Tecnologia dos EUA (NIST), o Guia Técnico de Testes e Avaliação de Segurança da Informação fornece recomendações práticas para projetar, implementar e manter processos e procedimentos de pentest.

3 ETAPAS DO PENTEST

Juntamente com padrões e estruturas, existem vários processos que podem ser usados para o pentest. Esses processos são de estrutura semelhante, na maioria das vezes e, geralmente, refletem os processos reconhecidos por produzir um ataque cibernético bem-sucedido. Neste exemplo, os estágios do processo de ataque cibernético também são os estágios intermediários do processo de pentest.

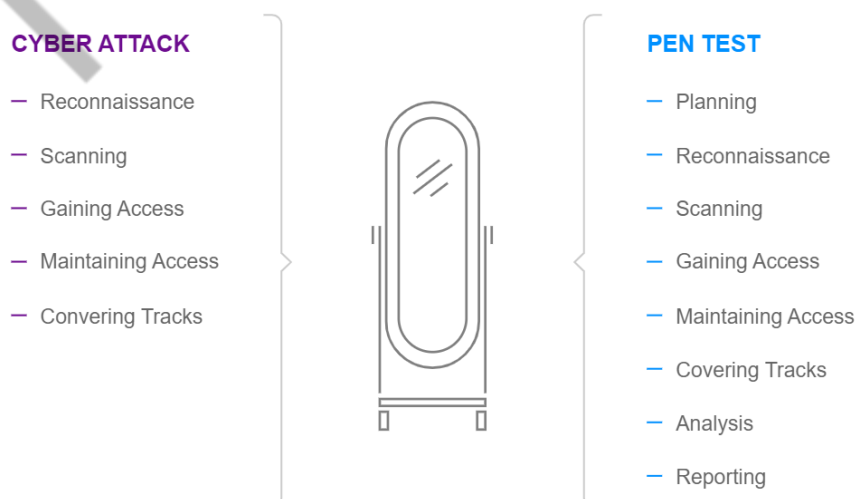


Figura 2 – Etapas do pentest

Fonte: Elaborado pelo autor (2019)

As etapas adicionais desse pentest fornecem o andaime que garante que os testes pretendidos sejam conduzidos e que os resultados sejam comunicados aos tomadores de decisão. Em alguns casos em que o teste automatizado é usado, as fases de análise e relatório podem ser substituídas por uma fase para implementar as definições de configuração.

Planejamento	A maioria dos processos de pentest reconhecidos inclui uma fase de planejamento. Dependendo da autoridade que promulga o processo, esta fase também pode incluir a identificação do escopo do trabalho, a documentação de detalhes logísticos e outras atividades preliminares que precisam ocorrer antes do início do pentest.
Reconhecimento	Na fase de reconhecimento, o testador reúne informações sobre a organização e os sistemas de destino antes do início do pentest. Isso pode incluir a coleta passiva de informações, como a coleta de informações publicamente disponíveis sobre a organização, e atos deliberados, como a verificação de portas para detectar possíveis vulnerabilidades.
Escaneamento	A fase de escaneamento geralmente é um pouco mais profunda que a fase de reconhecimento. É aqui que a avaliação da vulnerabilidade começa. As ferramentas de verificação estática e dinâmica avaliam como um alvo que responde a invasões.
Obtendo acesso	Esta fase é quando a exploração real começa aplicando as informações obtidas pelo reconhecimento e pela varredura para começar a atacar os sistemas de destino.
Mantendo o acesso	Nesta fase, os pentesters instalam mecanismos que permitem continuar acessando o sistema. Esta fase também é quando os pentesters se aprofundam na rede acessando outros sistemas de rede.
Faixas de cobertura	Esta fase se concentra na obliteração de evidências que provam que uma exploração ocorreu. Geralmente, consiste em duas facetas: evitar esforços de resposta a incidentes em tempo real e evitar responsabilidade forense pós-exploração.
Análise	Nesta fase, o pentest reúne todas as informações coletadas, identifica as causas principais de quaisquer vulnerabilidades detectadas e desenvolve recomendações para mitigação.
Relatórios	Na fase de relatórios, as informações dos testes e análises são oficialmente comunicadas às partes interessadas, embora os requisitos de relatórios possam variar devido às necessidades do cliente ou regulamentos legais. • Vulnerabilidades detectadas. • Vulnerabilidades exploradas. • Dados confidenciais acessados. • Quanto tempo o pentest teve acesso. • Sugestões e técnicas para combater vulnerabilidades.

4 COMUNICAÇÃO NO PROCESSO DE PENTEST

Como em qualquer tipo de revisão, interna ou contratada, a comunicação entre a equipe de teste e as partes interessadas é de suma importância. Devemos estar atentos a todas as facetas da necessidade de comunicação a ser avaliadas e decididas antes da contratação de pentest, tais como:

4.1 O caminho da comunicação ou cadeia de comando

Em uma situação de pentest, é de igual importância garantir que as pessoas certas sejam informadas sobre quais informações devem ser compartilhadas. Por exemplo, a organização pode não querer que todos os funcionários saibam quando está ocorrendo um pentest, principalmente se desejam verificar a eficácia do uso de táticas de engenharia social para penetrar na rede.

O gerente de TI do cliente e o CIO/CISO devem estar cientes do compromisso. Além disso, alguns gerentes de departamento importantes também devem estar cientes, caso incidentes imprevistos possam afetar seus departamentos.

4.2 Comunicação com o cliente

O líder designado da equipe de pentest deve ter uma comunicação próxima com a contraparte do cliente (normalmente o gerente de TI). Para reduzir a possível confusão, toda a comunicação entre a equipe de pentest e o cliente deve passar por esse ponto de contato. Os dois papéis principais devem ser práticos. Isso permite uma resposta imediata em caso de incidentes, descobertas inesperadas, solicitações adicionais do cliente ou qualquer outra coisa que possa levar a tempo prolongado ou aumento do escopo.

4.3 Comunicação dentro da equipe de pentest

A equipe de pentest também deve ter protocolos de comunicação interna. Por exemplo, subequipes que trabalham em tarefas específicas devem avaliar a liderança

de seu progresso. Eles devem informar imediatamente o líder sobre descobertas inesperadas, como evidências de violações de segurança anteriores ou se descobrirem a atividade atual de hackers. O lead entrará em contato com a contrapartida do cliente para discutir o que deve ser feito.

4.4 Quais informações comunicar e quando?

O que deve acionar as comunicações oficiais? Descrever quaisquer etapas do processo padrão, como as etapas de planejamento e elaboração de relatórios, que exijam a realização de reuniões. Caracterizar também as entregas reais, como status e relatórios intermediários, bem como o relatório final a ser fornecido. E quanto a "mostrar rolhas" ou outras descobertas críticas? A equipe de pentest deve ser capaz de priorizar descobertas à medida que ocorrem e identificar descobertas urgentes o suficiente para acionar comunicações especiais.

Quando um pentest encontra evidências de um sistema comprometido, a equipe de resposta a incidentes deve ser notificada para garantir que a organização esteja ciente do ataque? Se a evidência parecer "nova", talvez seja necessário suspender o pentest até que a violação de segurança seja tratada. Se for histórico, a equipe de pentest deve registrar a descoberta e continuar com a tarefa em mãos.

4.5 Briefings regulares de progresso dentro da equipe

Se diferentes membros da equipe de pentest estiverem realizando ataques simultâneos, deve haver coordenação interna para garantir que os membros da equipe não interfiram acidentalmente entre si. O líder pode optar por realizar reuniões diárias do tipo "scrum", nas quais cada membro descreve o que fez no dia anterior, o que fará no dia e identificar qualquer coisa que bloqueie seus esforços. O líder ou o gerente de projeto pode alocar recursos ou solicitar que atividades conflitantes sejam suspensas temporariamente.

4.6 Briefings regulares de progresso com o cliente

Se o pentest demorar mais do que alguns dias, o cliente poderá desejar atualizações regulares do progresso. Isso pode ser feito semanalmente ou conforme necessário. Lembre-se de que "o cliente" provavelmente não é apenas uma pessoa, mas pode haver vários gerentes que precisam permanecer no ciclo de comunicação. O cliente pode solicitar que esses gerentes recebam diretamente uma cópia das atualizações de status, ou podem solicitar que os relatórios sejam entregues a apenas um representante, que distribuirá cópias internamente.

Normalmente, o relatório final é entregue a uma única parte como parte de uma transferência formal. Em alguns casos, certas descobertas podem ser sensíveis demais para serem compartilhadas com todos na lista de destinatários aprovados. No entanto, é mais provável que essa seja a exceção e não a regra. Ter um caminho de comunicação claro garantirá que todas as partes relevantes recebam relatórios em tempo hábil. As emergências seriam tratadas separadamente, embora questões em andamento, como interferência do cliente, atrasos ou outros problemas, devam ser levantadas nas reuniões de status.

4.7 Identificação clara do raciocínio por trás das atividades de comunicação

Considere como uma situação pode precisar ser resolvida se a tentativa de pentest for detectada. É possível que vários testadores concentrem seus esforços em um sistema chave ao mesmo tempo, tornando a violação debilitante ou bastante óbvia. Nesse caso, a equipe de teste pode precisar trabalhar em conjunto para reduzir seus esforços para reduzir os efeitos do teste.

A conscientização situacional da equipe principal do cliente também pode ajudar a desconfiar a violação, permitindo que o pentest continue, para que problemas adicionais possam ser encontrados, explorados e analisados.

4.8 Possíveis ajustes no trabalho

A natureza de um pentest é que é um processo fluido. As informações descobertas durante a fase de reconhecimento orientam as decisões sobre quais explorações tentar e, finalmente, quais soluções propor. A conscientização da necessidade de planejamento de contingência para o próprio pentest permite incorporá-lo em seus planos e redefinir a prioridade dos objetivos de uma atividade ou grandes seções do pentest.

4.9 Divulgação dos resultados

Compete à empresa divulgar totalmente as vulnerabilidades e violações a seus clientes, fornecedores, reguladores ou membros do público que possam ser prejudicados pela violação. Se você, o pentest, tiver sido pago para ajudar a descobrir essas vulnerabilidades e violações, quaisquer descobertas deverão ser estritamente confidenciais por razões legais e éticas.

Uma exceção a isso poderia ser se você descobrisse uma conduta criminal; nesse caso, poderia ser obrigado a notificar a aplicação da lei. Se surgir uma pergunta sobre a divulgação das descobertas, mesmo que a divulgação seja para o bem do público em geral, não é tarefa do pentest tomar essa decisão. Você deve consultar o advogado da sua equipe nesses casos.

5 CONTRATO DE PENTEST

Como parte das questões legais relevantes ao processo de pentest, você encontrará vários tipos de acordos contratuais.

5.1 Contrato de serviço principal

Um contrato que estabelece precedência e diretrizes para qualquer documento comercial executado entre duas partes. Ele pode ser usado para cobrir custos

recorrentes e prever encargos adicionais durante um projeto sem a necessidade de um contrato adicional.

5.2 Declaração de trabalho e acordo de não divulgação (NDA)

Um documento de negócios que estipula que as partes não compartilharão informações confidenciais, conhecimento, ou materiais com terceiros não autorizados. Um documento comercial que define o nível mais alto de expectativa para um acordo contratual. Geralmente, inclui uma lista de entregas, responsabilidades de ambas as partes, marcos e cronogramas de pagamento e outros termos.

Como este documento detalha o que o cliente está pagando, ele tem um impacto direto nas atividades da equipe. Também pode ser usado pela equipe de pentest para cobrar solicitações fora do escopo e custos adicionais incorridos pelo cliente.

5.3 Autorizações

Outra faceta de estabelecer e realizar um trabalho de pentest envolve o processo de coleta de autorizações escritas para realizar as atividades de teste. Em algumas situações, os documentos de autorização (que podem ser preenchidos e assinados, cartas ou outros tipos de documentos) existem como adendos à SOW.

Os documentos de autorização por escrito ajudam a controlar a quantidade de responsabilidade incorrida pelo pentest. Nas situações em que um provedor de serviços de terceiros, como um provedor de serviços em nuvem, pode ser afetado, sendo necessário garantir que você tenha a devida autorização do provedor de serviços, além do cliente.

A maioria dos documentos de autorização por escrito deve incluir as seguintes informações:

- Quem é a autoridade de assinatura adequada ou quem pode autorizar a realização do pentest. Isso inclui uma declaração de que o abaixo-assinado é uma autoridade de assinatura da organização.

- Quem está autorizado a realizar o pentest.
- Quais redes, *hosts* e aplicativos específicos podem ser testados.
- O período em que a autorização está ativa.

Por fim, é altamente recomendável que todas as partes providenciem uma revisão legal do documento de autorização.

Restrições legais: além dos requisitos contratuais específicos, outras diferenças legais que dependem do ambiente da sua organização podem afetar o processo de pentest.

Restrições à exportação: nos Estados Unidos, os controles de exportação regulam o envio ou a transferência de determinados itens fora dos EUA. Esses itens podem incluir software, tecnologia, serviços e outros itens controlados. Outras nações podem ter restrições semelhantes ao compartilhamento de certos itens fora de suas fronteiras.

Restrições governamentais locais e nacionais: é altamente provável que as restrições governamentais controlem o uso da tecnologia e das ferramentas usadas durante o processo de pentest. Isso inclui não apenas a tecnologia e as ferramentas, mas também as informações coletadas pelos testadores e até o processo real de exploração dos sistemas de computadores, como a verificação de portas.

Políticas corporativas ou organizacionais: muitas empresas e organizações agora têm políticas específicas que regulam as atividades de pentest, portanto, você deve estar ciente de quaisquer restrições específicas adotadas pela empresa ou organização que está passando pelo pentest.

6 ESCOPO DO PENTEST

É essencial que cada trabalho de pentest tenha limites claros que sejam entendidos e acordados por ambas as partes. Embora muitas vezes conduzido em conjunto com o planejamento inicial, você ainda precisa garantir que as considerações de escopo sejam as mais precisas possíveis para fornecer orientação e definição de nível para a organização do cliente e para a equipe de teste, particularmente no caso

de grandes ou complexos compromissos que talvez precisem ser implementados em estágios.

Definir o escopo do seu compromisso é uma das coisas mais cruciais que você pode fazer ao negociar um contrato. O escopo é a base da SOW. Quando o escopo é claro, todas as partes interessadas entendem o que é considerado um alvo apropriado e os limites do que a equipe de pentest pode fazer com esse alvo. Os membros da equipe de pentest devem saber qual protocolo seguir quando encontrarem algo fora do escopo.

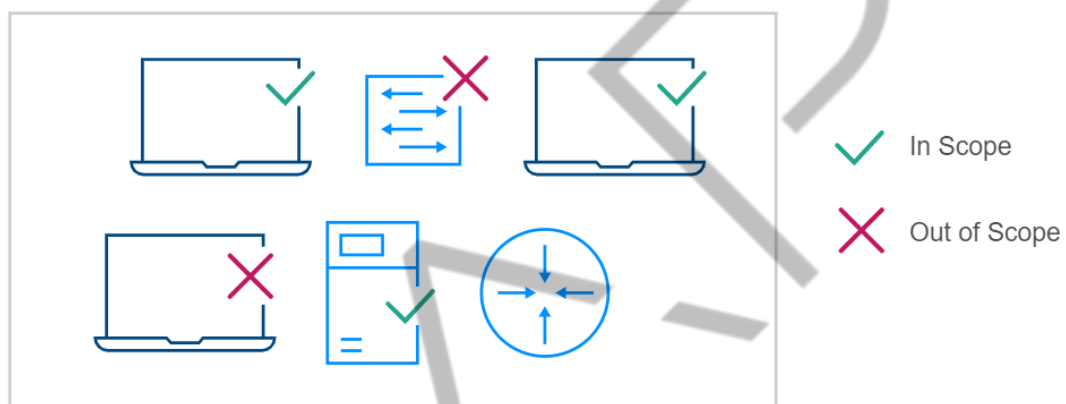


Figura 3 – Escopo do pentest
Fonte: Elaborado pelo autor (2019)

Por exemplo, é muito comum alguém do departamento de TI do cliente pedir pequenos favores aos consultores ou "verificar esse item" no exercício de suas funções.

O pentest deve saber se a solicitação está dentro do escopo e, se não estiver, como responder e escalar a solicitação. Geralmente, a resposta deve ser educada, podendo dizer, por exemplo: "Deixe-me verificar com meu supervisor como podemos ajudá-lo com isso".

Antes que uma organização possa começar o escopo de um trabalho de pentest, ela precisa identificar claramente por que o pentest está cumprindo uma conformidade, outro requisito legal ou verificar se existe uma necessidade e desejo definitivos de melhorar a segurança organizacional.

Existe a possibilidade de que, à medida que o planejamento e o escopo continuem, os objetivos finais possam precisar ser ajustados ou alterados.

Em praticamente todos os trabalhos de pentest, o principal produto a ser entregue é um relatório acionável que descreve os testes executados, as vulnerabilidades identificadas, a análise realizada e as soluções de mitigação sugeridas. Se for necessária mais ou diferente documentação da organização, essa necessidade deverá ser comunicada à organização, a entidade de teste antes da finalização do plano.

A equipe de teste precisa traduzir as descobertas técnicas no risco potencial para a organização. O relatório final deve incluir uma seção que classifique as ameaças por probabilidade x impacto. Em alguns casos, isso se traduzirá diretamente em perdas monetárias, enquanto em outros, em questões legais ou perda de reputação, que então se correlacionam com perdas monetárias. Essa classificação ajudará o cliente a priorizar os esforços e os prazos de correção.

Existem várias categorias gerais de avaliação que uma organização pode usar para ajudar a definir o escopo de um trabalho de pentest. As avaliações com base em metas ou em objetivos fornecem pontos de foco para o pentest. Elas começam pelo cliente listando os itens ou informações que precisam ser protegidos. Em seguida, a equipe de pentest desenvolverá planos para obter a meta ou objetivo por meio de qualquer técnica de ataque disponível. Essa abordagem imita de perto os ataques que podem ser lançados por uma parte mal-intencionada, para que eles possam fornecer um ROI significativo para a organização do cliente.

As avaliações baseadas em conformidade são testes exigidos pelo governo ou pelo setor, com base em uma estrutura de conformidade estabelecida. As estruturas de conformidade comuns nos EUA incluem [Payment Card Industry Data Security Standard- PCI DSS](#), [Security Technical Implementation Guide from Defense Information Systems Agency - DISA STIG](#), [Federal Risk and Authorization Management Program – FedRAMP](#) e [Federal Information Security Modernization Act – FISMA](#).

As avaliações de red team testam os recursos de detecção e resposta de uma organização emulando um ator mal-intencionado que tem como alvo ataques e evita a detecção. O red team acessa informações confidenciais da maneira que puder, sem ser pego em flagrante. As equipes vermelhas geralmente têm prazos mais longos para trabalhar.

Como furtividade e prevenção são de grande importância para a equipe vermelha, eles funcionam mais como uma ameaça persistente avançada (APT), mantendo um perfil baixo enquanto se infiltram na rede.

Por outro lado, as equipes de pentest geralmente têm tempo limitado e muitas vezes não podem se dar ao luxo de ser pacientes. Como tal, elas podem ser "barulhentas", enquanto os red teams são "mais silenciosos".

A ideia de equipes de cores evoluiu a partir de exercícios militares. Em geral, equipes vermelhas (red team) atacam, enquanto equipes azuis (blue team) defendem. Em alguns casos, equipes roxas (purple team) ajudam a coordenar interações entre equipes vermelhas e azuis e, em outros casos, equipes brancas (white team) estabelecem regras e monitoram os testes.

6.1 Avaliações baseadas em conformidade

Conformidade é uma disciplina mais ampla na qual o pentest pode, mas não necessariamente precisa, desempenhar um papel. A conformidade é geralmente avaliada por meio de uma auditoria abrangente dos controles administrativos, técnicos e físicos, seu design, implementação, manutenção e eficácia.

O teste de penetração pode ser usado para validar a eficácia de muitos desses controles. Como a conformidade é exigida pelo governo ou pelo setor, prevaleceria sobre qualquer política da empresa. Os principais aspectos das avaliações baseadas em conformidade incluem:

- Objetivos definidos com base em regulamentos ou estruturas de conformidade (o que procurar).
- Possíveis regras obrigatórias para a conclusão da avaliação (como procurar).
- Concentre-se em políticas de senha, isolamento de dados e gerenciamento de chaves.
- Limitações no acesso à rede ou ao armazenamento.

A seguir, descreve os tipos de estratégias usadas na maioria dos trabalhos de pentest. Além disso, o tipo de estratégia que você usa terá um efeito no escopo do projeto.

6.2 Black-box testing

O pentest praticamente não fornece informações sobre os sistemas ou redes que estão sendo testados, simulando um invasor externo que sabe pouco sobre o alvo além do que pode ser determinado por meio de técnicas básicas de reconhecimento.

Também conhecido como teste de zero conhecimento, o pentest deve coletar informações sobre o destino e verificar essas informações com o cliente antes que o teste real possa começar. A verificação do cliente confirma que o teste está sendo realizado dentro do escopo estabelecido.

Os testes geralmente são realizados com pouquíssimas pessoas na organização de destino sabendo disso, fornecendo um teste de como o pessoal monitora, detecta e responde a incidentes de segurança.

6.3 Gray-box testing

O pentest é fornecido com algum conhecimento e percepção de arquiteturas e sistemas internos, além de outras informações preliminares sobre o destino e seus ativos, para simular um invasor interno que conhece algumas, mas não todas, informações sobre os sistemas e redes de destino.

Também chamado de teste de conhecimento parcial, o pentest tenta coletar informações adicionais sobre o alvo por meio de técnicas básicas e avançadas de reconhecimento.

6.4 White-box testing

O pentest é fornecido com conhecimento sobre todos os aspectos dos sistemas e redes de destino, para simular um invasor interno que possui amplo conhecimento dos sistemas e redes que estão sendo direcionados. Considerado o oposto de um

teste de caixa preta, geralmente é realizado um teste de caixa branca como acompanhamento de um teste de caixa preta. Como o testador já possui informações sobre a função e o design dos alvos, a fase de reconhecimento pode ser ignorada.

Como na estratégia de caixa preta/cinza/branca, o escopo efetivo de um compromisso envolve determinar quais tipos diferentes de atacantes serão emulados. Algumas organizações se preocupam principalmente com ameaças externas, enquanto outras exigem uma abordagem mais abrangente.

- **Threat actor:** é uma entidade que é parcial ou totalmente responsável por um incidente que afeta ou tem o potencial de afetar a segurança de uma organização. Os atores de ameaças também são chamados de atores maliciosos. Uma maneira comum de categorizar os atores de ameaças é de natureza descritiva: Script kiddies são hackers novatos ou inexperientes, com conhecimento técnico limitado, que contam com ferramentas automatizadas para invadir alvos.
- **Hacktivistas:** obtêm acesso não autorizado e causam interrupções nos sistemas de computador, na tentativa de alcançar mudanças políticas ou sociais. Os autores de crimes organizados se envolvem em atividades criminosas, incluindo crimes cibernéticos, geralmente com fins lucrativos. Estados-nações e ameaças persistentes avançadas (APTs) usam crimes cibernéticos para atingir objetivos políticos e militares. Os APTs geralmente usam vários vetores de ataque para garantir seu sucesso em obter acesso não autorizado a informações.
- **Insider threats** envolvem alguém de dentro ou relacionado à organização de destino. Os insiders incluem funcionários atuais e antigos, contratados, parceiros e qualquer entidade que tenha acesso a informações proprietárias ou confidenciais.

Como você pode ver nas descrições de níveis da seção anterior, diferentes tipos de atores de ameaças podem ter níveis variados de capacidade. É menos provável que os atores de camadas inferiores tenham mais recursos de desenvolvimento de aplicativos do que os atores de camadas intermediárias e superiores.

Cada ator de ameaça também possui um ou mais motivos principais para conduzir ataques. Alguns atores de ameaças podem estar mais motivados por ganhos monetários, enquanto outros lutam pelo poder ou até por vingança. Essas motivações variadas estão diretamente ligadas à intenção do ator da ameaça. Se a ganância é o motivador, a intenção é roubar informações.

6.5 Contrato de confidencialidade

Construindo um contrato de confidencialidade conforme exemplo a seguir:

Anexo I – Acordo de Confidencialidade

A **CONTRATANTE** (XXXXXXXXXX) e a **CONTRATADA** (XXXXXXXXXX) acordam entre si:

1. A **CONTRATANTE** entrega a **CONTRATADA** informação de sua propriedade relativa às configurações de segurança de seus dispositivos informáticos sujeitos ao objeto da atividade contratada (Teste de Intrusão).
2. A informação entregue pela **CONTRATANTE** à **CONTRATADA** e vice-versa, relacionada ao objeto ou mesmo produto da atividade contratada se constitui Informação Confidencial.
3. A **CONTRATADA** se obriga a:
 - a. Manter em caráter sigiloso a Informação Confidencial e não disponibilizá-la a terceiros sem o consentimento da **CONTRATANTE**.
 - b. Utilizar a Informação Confidencial exclusivamente para a atividade contratada e tarefas definidas no escopo deste trabalho.
 - c. Restituir toda a Informação Confidencial toda vez que esta for solicitada pela **CONTRATANTE**.
 - d. Destruir toda Informação Confidencial com solicitação e consentimento da **CONTRATANTE**, a qual a **CONTRATADA** deverá provar tal destruição.
 - e. Revelar a Informação Confidencial somente às pessoas cujo conhecimento é indispensável para atender a finalidade da atividade contratada. Estas pessoas devem manter as obrigações aqui previstas e a **CONTRATADA** responderá somente a elas.
 - f. Eliminar toda cópia eletrônica e/ou impressa da Informação Confidencial de qualquer equipamento informático ou outros equipamentos de apoio, salvo autorização expressa da **CONTRATANTE**, uma vez que o trabalho seja finalizado.
4. A **CONTRATADA** está liberada de sua obrigação em guardar segredo da Informação Confidencial caso:
 - a. As evidências fornecidas pela **CONTRANTE**, sejam de prévio conhecimento da **CONTRATADA** em período anterior à atividade contratada.
 - b. As informações sejam publicamente conhecidas sem que resultem no descumprimento da **CONTRATADA** ou de um terceiro sujeito a uma obrigação de confidencialidade.
 - c. Exista uma obrigação jurídica de fornecimento da informação. Neste caso a **CONTRATADA**, poderá revelar somente o mínimo de Informação Confidencial necessário para o cumprimento da exigência legal. Neste caso, a informação apenas será fornecida depois da notificação formal a ambas as partes. Este direito também poderá ser exercido pela **CONTRATADA** no dia do vencimento do prazo para provimento desta informação, descrito no requerimento jurídico.
5. A **CONTRATADA** está ciente que:
 - a. A **CONTRATANTE**, não outorga nenhuma garantia a respeito da Informação Confidencial, salvo que este conteúdo é de sua propriedade e tem todo direito em revelá-la.
 - b. A Informação Confidencial pode conter erros, ser inexata, não ser aplicável ou não se destinar à questão da atividade contratada.

- c. A **CONTRATADA** é exclusivamente responsável pela atualização da Informação Confidencial, o uso que ela outorgue e os efeitos que esta atualização resulte.
- d. A Informação Confidencial tem um valor estratégico para a **CONTRATANTE**.

6. A **CONTRATANTE** está ciente que:

- a. Os documentos entregues (impressos ou eletrônicos) serão de acesso exclusivo aos responsáveis pela empresa contratante e/ou área contratante.

6.6 Instalação Kali Linux

Após efetuar o download da imagem desejada e queimar um DVD (ou criar uma VM), inicie a máquina para começar o processo de instalação do sistema. Será apresentada a tela a seguir. Selecione a opção Graphical install e pressione Enter no teclado:



Figura 4 – Instalação Gráfica
Fonte: Elaborado pelo autor (2019)

Na tela seguinte, selecione o idioma que será usado durante o processo de instalação – no caso, Português do Brasil, clique em Continue.

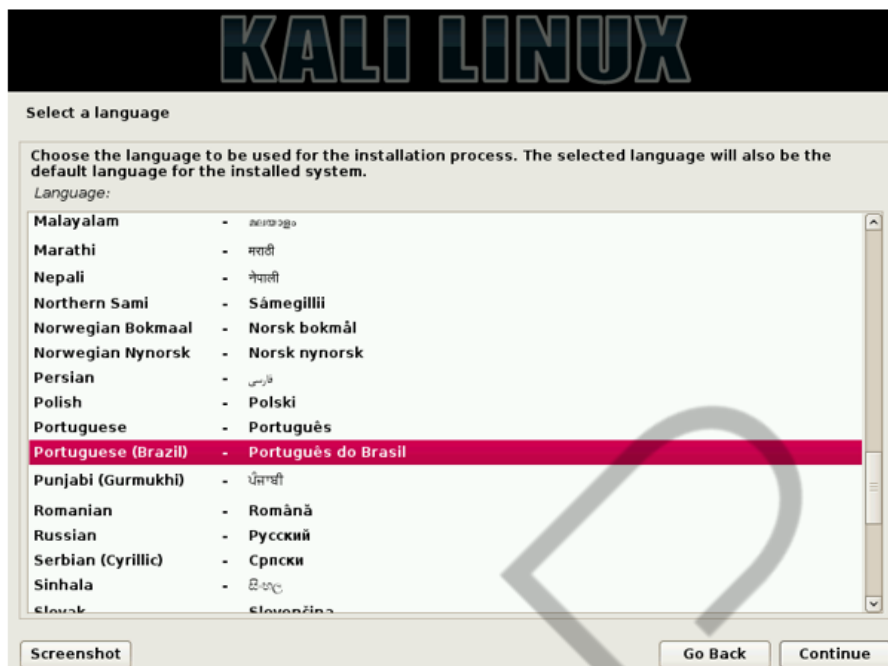


Figura 5 - Português Brasil
Fonte: Elaborado pelo autor (2019)

O software irá lhe informar que a tradução do instalador está incompleta para o idioma selecionado e irá perguntar se deseja continuar a instalação no idioma selecionado. Clique em “Sim” e depois em “Continuar”:

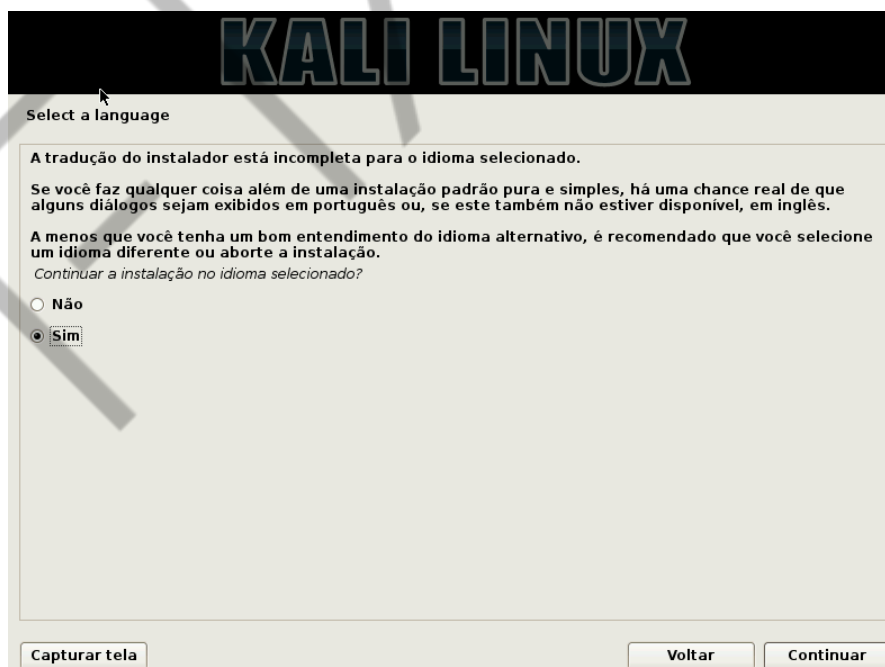


Figura 6 – Linguagem
Fonte: Elaborado pelo autor (2019)

Agora selecione o seu país, território ou área e, depois, clique em “Continuar”:

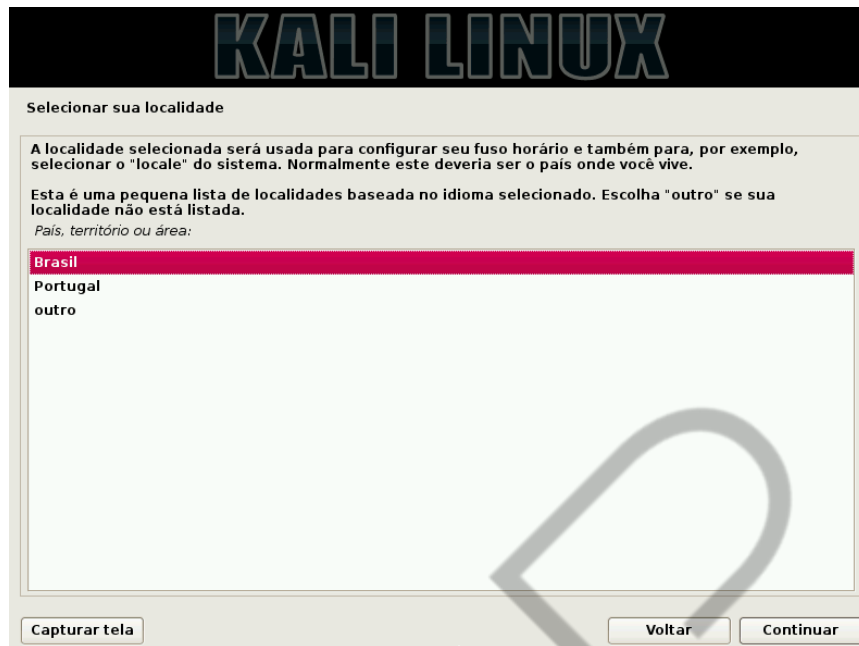


Figura 7 – Brasil
Fonte: Elaborado pelo autor (2019)

Na tela seguinte, vamos configurar o teclado. Selecione sua opção (no meu caso, Português Brasileiro) e clique em “Continuar”:

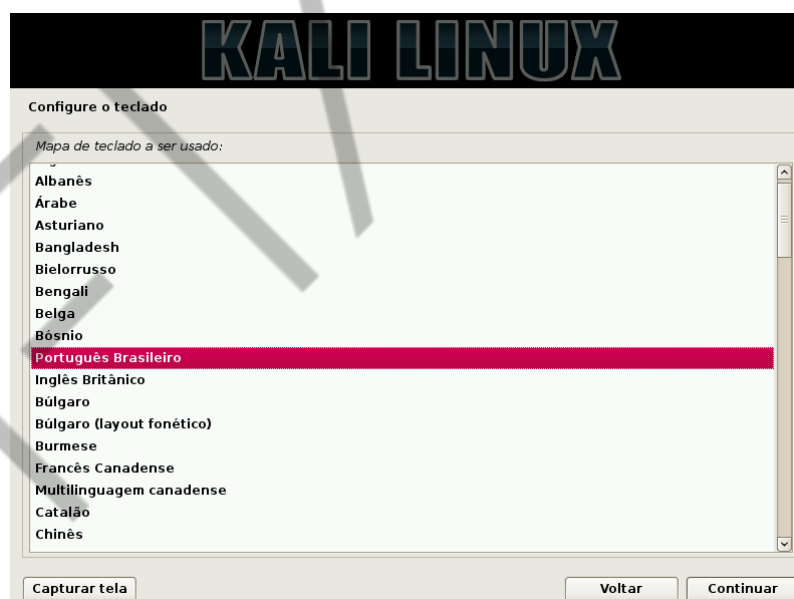


Figura 8 - Português Brasileiro
Fonte: Elaborado pelo autor (2019)

Agora aguarde enquanto os componentes do instalador são carregados a partir do CD:



Figura 9 - Carregando Componentes
Fonte: Elaborado pelo autor (2019)

Na tela seguinte, informe o nome de máquina a ser usado (hostname). Vou usar simplesmente "kali". Clique em "Continuar":

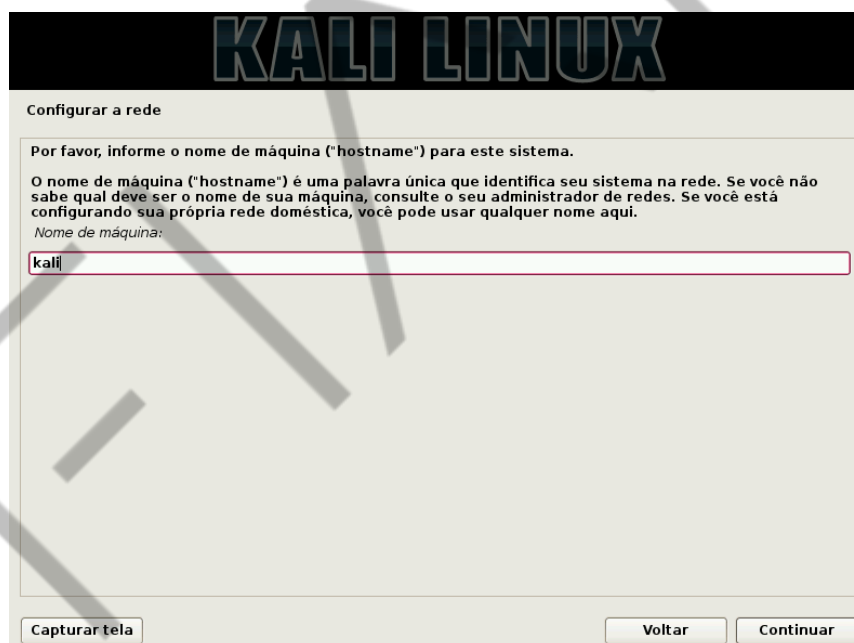


Figura 10 - Nome da máquina
Fonte: Elaborado pelo autor (2019)

Digite o nome de domínio a ser utilizado. Se não tiver um nome de domínio, apenas deixe em branco a caixa de texto e clique em "Continuar":



Figura 11 - Nome do domínio
Fonte: Elaborado pelo autor (2019)

Na tela seguinte você deve escolher uma senha para o usuário root, que é o administrador do sistema. Digite-a e repita-a para confirmar nas caixas apropriadas, e então clique em “Continuar”:

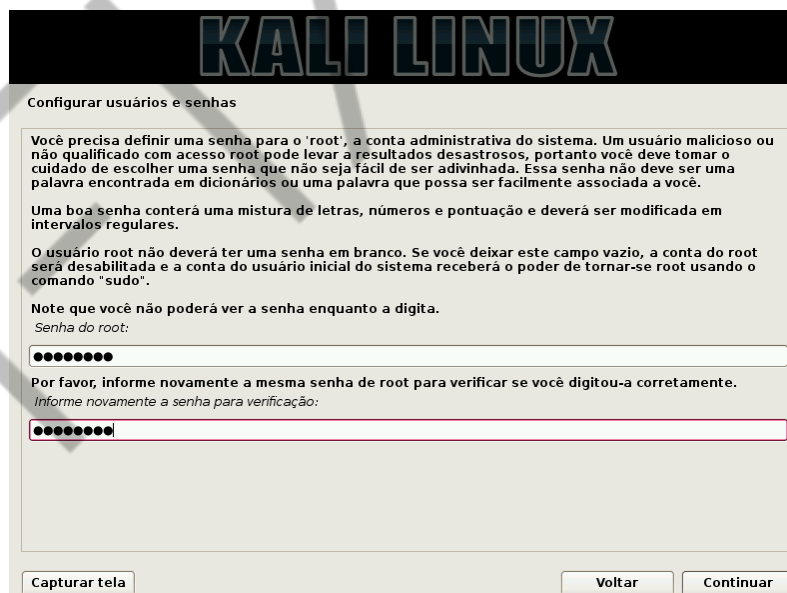


Figura 12 – Senhas
Fonte: Elaborado pelo autor (2019)

Configure agora seu fuso horário, selecionando seu estado ou província na lista e, depois, clique em “Continuar”:

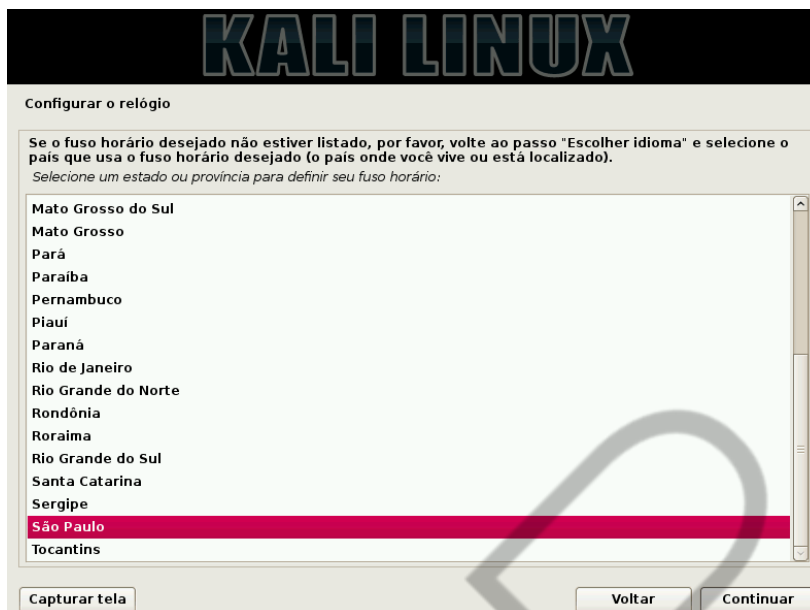


Figura 13 – Relógio
Fonte: Elaborado pelo autor (2019)

Na tela seguinte você deve escolher o método de particionamento. Para simplificar, vou escolher o método Assistido – usar o disco inteiro. Clique em Continuar:

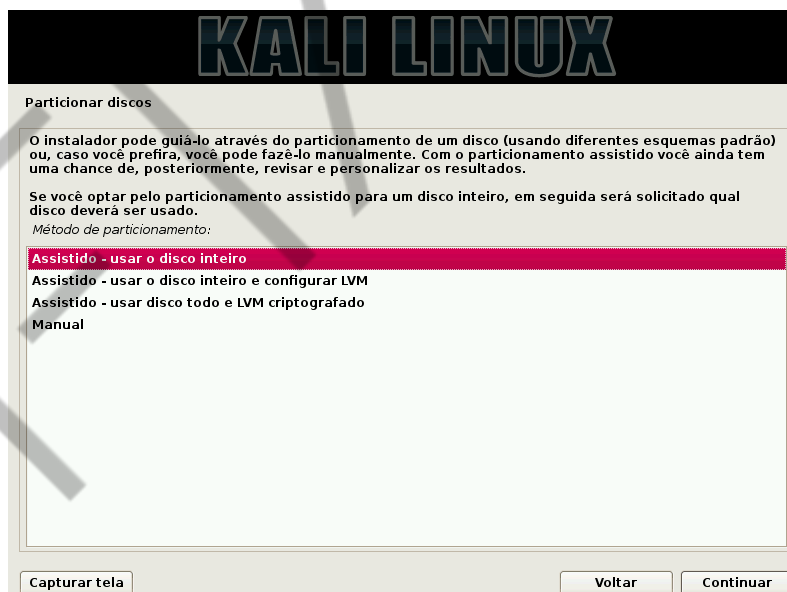


Figura 14 – Disco
Fonte: Elaborado pelo autor (2019)

Selecione o disco que deverá ser particionado e formatado, clique novamente em “Continuar”:



Figura 15 - Selecionar disco
Fonte: Elaborado pelo autor (2019)

Agora escolha o esquema de particionamento. Para simplificar, vou escolher o esquema “Todos os arquivos em uma partição (para iniciantes)”. Clique em “Continuar”:

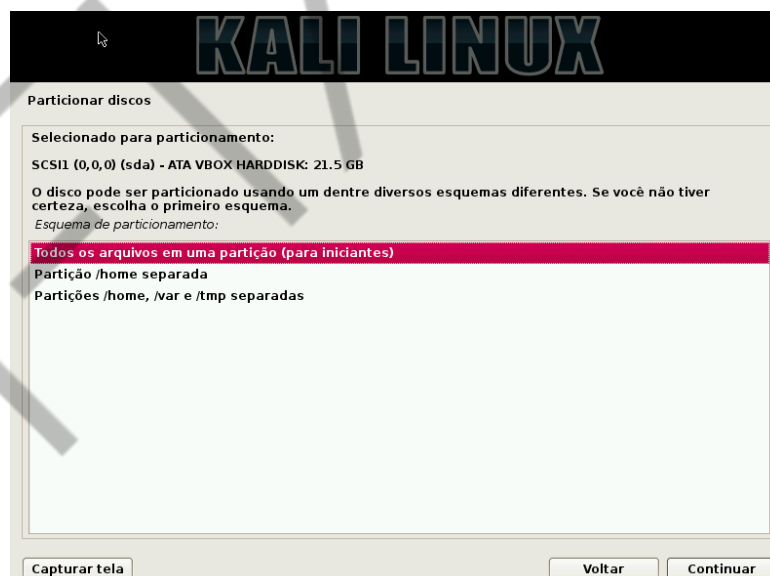


Figura 16 - Selecionar Partição
Fonte: Elaborado pelo autor (2019)

Na tela seguinte, verifique se as opções escolhidas aparecem como desejado – serão criadas duas partições, uma primária com sistema de arquivos ext4 e uma unidade lógica de swap. Clique em “Continuar”.

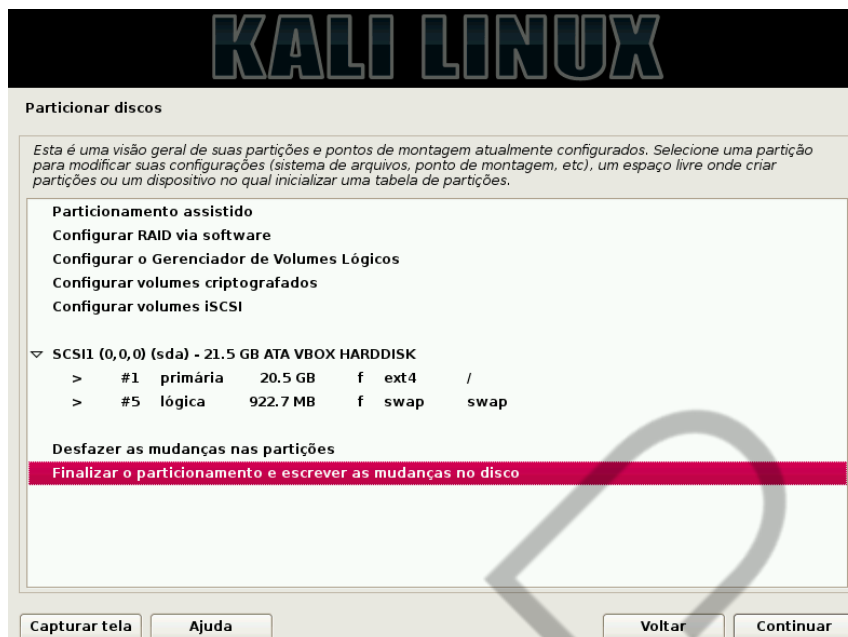


Figura 17 - Aplicar Particionamento

Fonte: Elaborado pelo autor (2019)

Na tela seguinte, clique em “Sim” para responder à pergunta “Escrever as mudanças nos discos” e clique em “Continuar”:



Figura 18 - Escrever mudanças

Fonte: Elaborado pelo autor (2019)

Agora aguarde enquanto o sistema é instalado. Essa operação pode levar vários minutos.

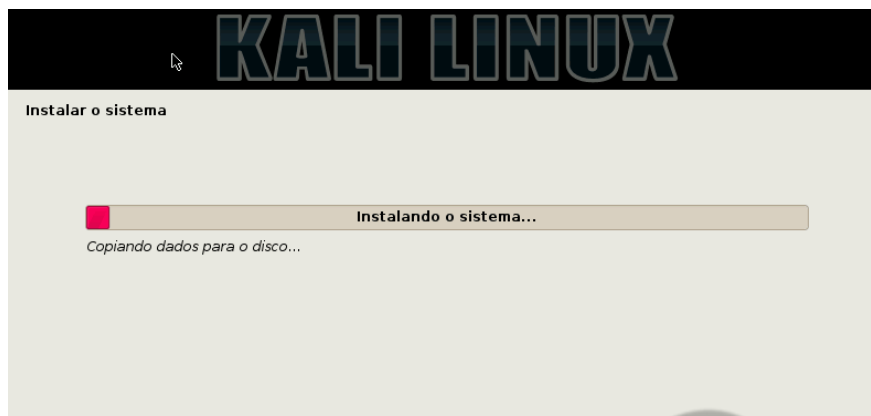


Figura 19 - Instalando Sistema
Fonte: Elaborado pelo autor (2019)

Após algum tempo, será perguntado se deseja usar um espelho de rede para suplementar o software que está incluído no CD-ROM. Clique em Não e então em Continuar:

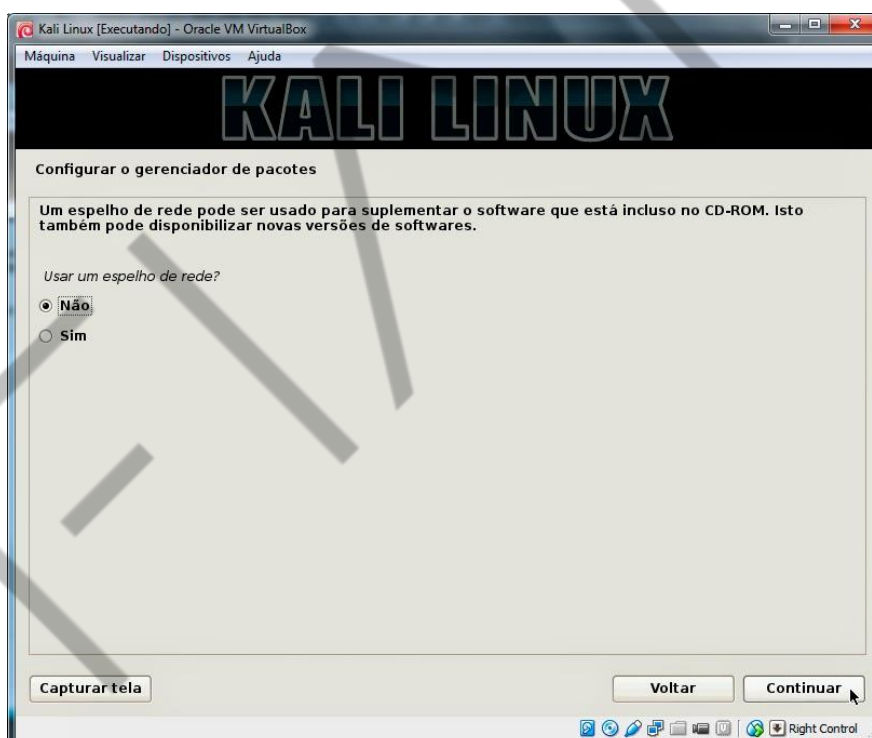


Figura 20 - Espelho de rede
Fonte: Elaborado pelo autor (2019)

Agora você deve informar o endereço do servidor proxy de sua rede – se houver. Neste exemplo, foi deixado em branco, pois não há proxy na rede na qual foi efetuado a instalação do Kali Linux. Clique em “Continuar”:

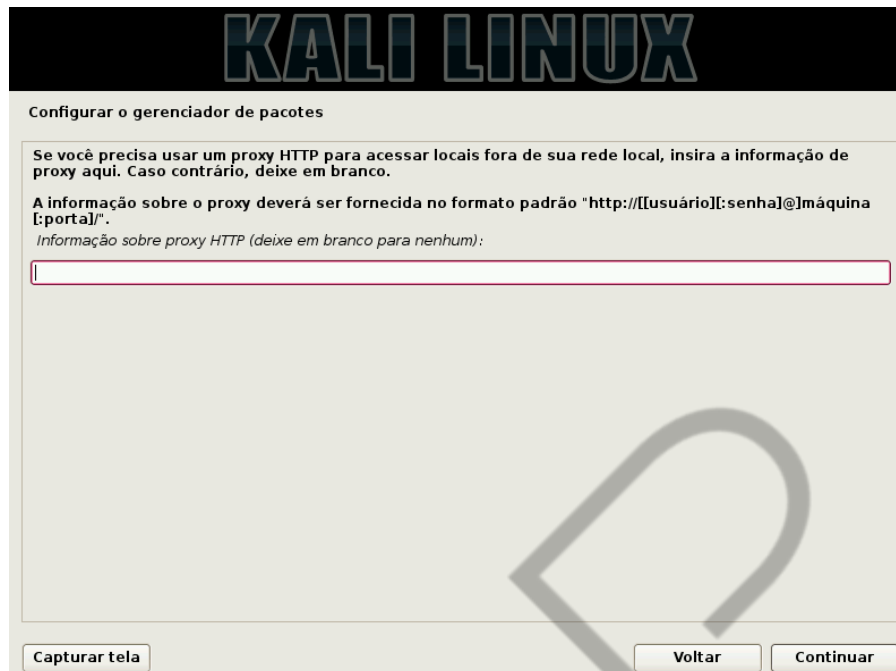


Figura 21 – Proxy
Fonte: Elaborado pelo autor (2019)

Aguarde enquanto o gerenciador de pacotes é configurado:

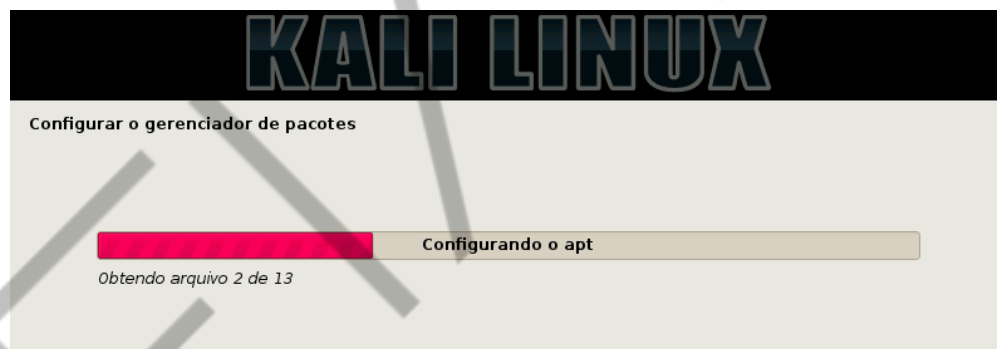


Figura 22 - Terminando instalação
Fonte: Elaborado pelo autor (2019)

Estamos quase lá! Será perguntado se deve instalar o carregador de inicialização GRUB no registro mestre de inicialização. Marque a opção “Sim” e, então, clique em “Continuar”:



Figura 23 - Configurando GRUB
Fonte: Elaborado pelo autor (2019)

Aguarde enquanto o GRUB é instalado:

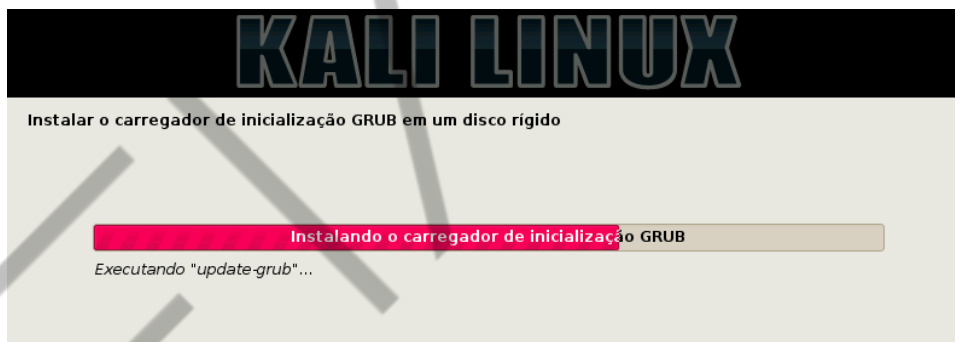


Figura 24 - Instalando GRUB
Fonte: Elaborado pelo autor (2019)

E a instalação será finalizada! Retire o DVD do drive e clique em "Continuar" para reiniciar o computador e dar boot na nova instalação do Kali Linux:

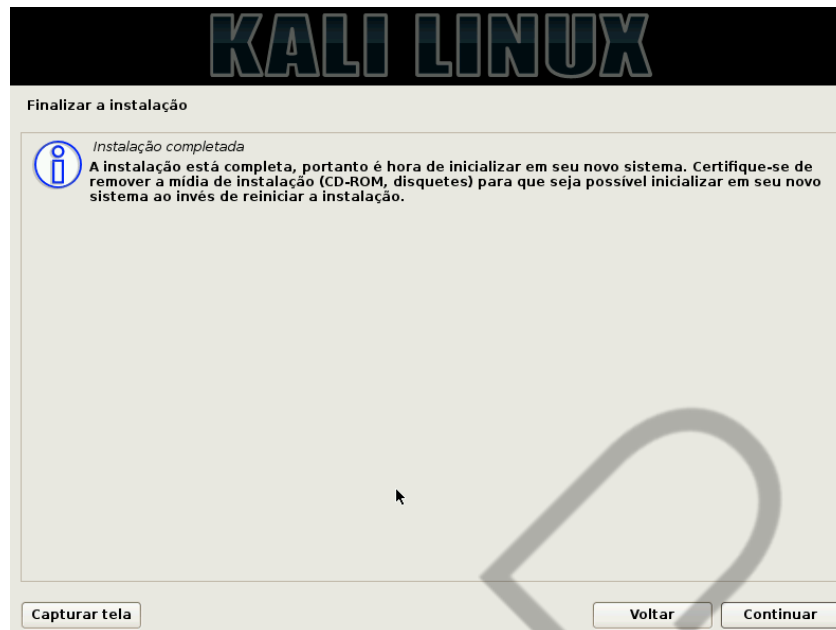


Figura 25 - Finalizar Instalação
Fonte: Elaborado pelo autor (2019)

Após reiniciar, será apresentada a tela de login do sistema. Digite o nome de usuário root e clique no botão “Entrar”:

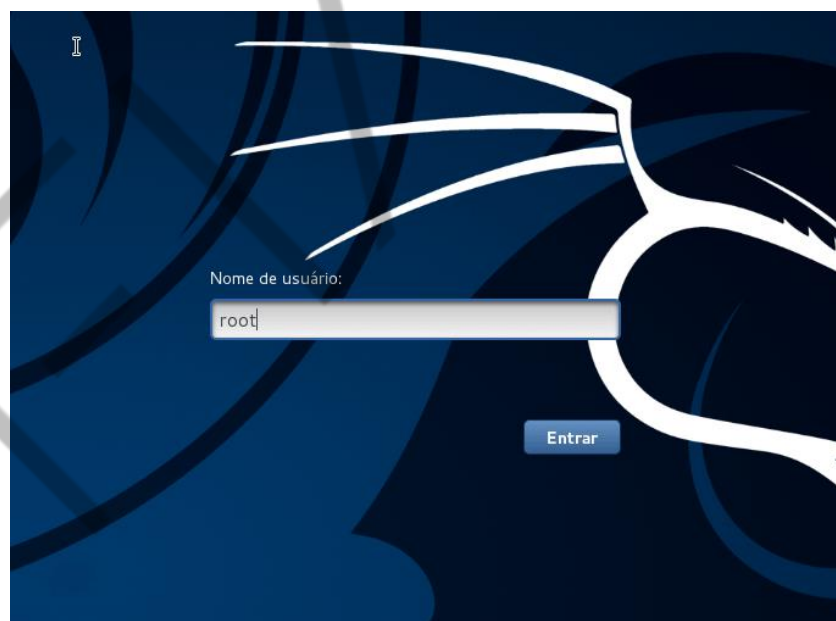


Figura 26 - Login como root
Fonte: Elaborado pelo autor (2019)

E na sequência, entre com sua senha e clique novamente em “Entrar”. Após o perfil ser criado e carregado, será apresentada a área de trabalho do Kali Linux. Instalação finalizada com sucesso! Agora é só começar a explorar e usar o sistema.

REFERÊNCIAS

KENNEDY, D.; O'GORMAN, J.; KEARNS D. **Metasploit**: The Penetration Tester's Guide. San Francisco, California: No Starch Press, 2011.

NASSIF, T. Veja quais são as profissões mais promissoras para 2022, segundo o LinkedIn. **CNN Brasil**, 18 jan. 2022. Disponível em: <<https://www.cnnbrasil.com.br/business/veja-quais-sao-as-profissoes-mais-promissoras-para-2022-segundo-o-linkedin/>>. Acesso em: 29 abr. 2022.

WEIDMAN, G. **Penetration Testing**: A Hands-On Introduction to Hacking. San Francisco, California: No Starch Press, 2014

WILHELM, T. **Professional Penetration Testing**: Creating and Learning in a Hacking Lab. 2. Ed. Waltham, MA: Syngress, 2013.